CLAUDE CODE DEEP DIVE WORKSHOP · FSI EDITION

Chapter 3 - 가드레일·DLP

무엇을 못 하게 할 것인가

Update : 2026.11 / Claude Code v2.1.319 (2026-11-08 리허설 검증) · Amazon Bedrock · 공식 문서 code.claude.com/docs 반영

Choi, WooHyung
Prin. Solutions Architect
AWS Korea
whchoi@amazon.com

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

Chapter 3 Agenda

4 Parts + Lab / 강의 18분 · 실습 32분

PART 01	설정·권한 기초	스코프 우선순위, 평가 순서, 잠금 키	3분
PART 02	auto mode와 안전의 경계	auto mode · 승인 추가 · 분류기 모델 · 경계	5분
PART 03	DLP 5층	권한 · 샌드박스 · 훅 · Guardrails · 반출 채널	7분
PART 04	확장 통제와 감사	플러그인·MCP·mod, 남는 기록	3분
LAB	DLP 훅·fail-open·auto mode	TASK 00~03·07, 선택 04~06	32분
MORE	더 알아보기	자주 묻는 세부 내용	참고

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

03

가드레일·DLP

권한 · 샌드박스 · 훅 · Guardrails · 확장 통제

PRE-SURVEY

51 / 138

참가 확정자 중 51명이 "망분리·보안 (DLP·감사로그)"를 기대 주제로 골랐습니다

규제·감사 대응 44명 · 팀 표준화 58명 (복수 선택)

CHAPTER 03 / PART 01

설정·권한 기초

가드레일을 읽기 위한 문법

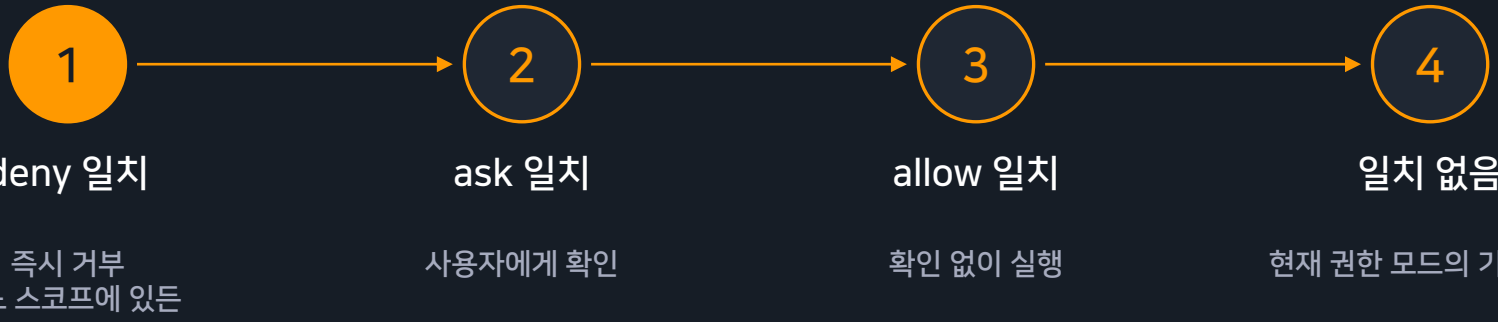
1. 누가 이기는가
2. deny가 항상 이긴다
3. 잠금 키

권한 평가 순서

deny가 항상 이깁니다

RULE

규칙은 Managed·Project·User 등 모든 스코프에서 합쳐진 뒤 평가됩니다. 어디에 있든 deny에 걸리면 거부입니다.



© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

규칙 문법

Tool(specifier) 한 가지 형식

permissions

```
"deny": [
  "Read(./.env)",             // 정확한 파일
  "Read(./secrets/**)",       // gitignore 스타일 글롭
  "Bash(curl *)",             // 명령 패턴
  "WebFetch(domain:pastebin.com)",
  "mcp__untrusted-server"     // MCP 서버 전체
],
"ask":   ["Bash(git push *)"],
"allow": ["Bash(npm run test *)"]
```

현장에서 걸리는 지점

- Bash 패턴은 우회가 쉬움 → 샌드박스와 함께
- 경로는 ./ 기준 상대 경로
- MCP는 mcp__서버명 단위
- 복잡한 판단은 훅으로

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

QUICK CHECK · 손을 들어 답해 주세요

Q. user settings에 allow "Bash(curl *)", managed에 deny "Bash(curl *)". 결과는?

A
그대로 실행

B
확인 후 실행

C
거부

D
나중 설정이 이김

정답 C · 권한 규칙은 합쳐지고, deny가 먼저 평가됩니다

잠금 키

managed에 배포하는 잠금 스위치 (일부는 어느 설정 파일에나 둘 수 있음)

키	효과	권고
allowManagedPermissionRulesOnly	사용자·프로젝트의 권한 규칙 무시	규제 환경 기본
permissions. disableBypassPermissionsMode	권한 우회 모드 금지	항상
allowManagedHooksOnly	managed·허용된 훅만 실행	DLP 훅과 함께
allowedHttpHookUrls	HTTP 훅 목적지 제한 (어느 설정 파일에나, 배열 병합)	감사 수집기만
minimumVersion	자동 업데이트가 이 버전 아래로 설치하지 않음 (어느 설정 파일에나)	보안 수정 반영
strictKnownMarketplaces	플러그인 출처 허용 목록	Part 4

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

CHAPTER 03 / PART 02

auto mode와 안전의 경계

auto mode · 승인 피로와 사고 사이

1. 승인 피로
2. 권한 모드 한눈에 보기
3. auto mode 판정 순서
4. 승인을 추가하는 법
5. 분류기 모델 고르기
6. 어디까지 허용할까

APPROVAL FATIGUE

확인 창이 많으면 사람은 읽지 않고 누릅니다

— 프롬프트 수를 줄이는 것이 오히려 안전을 높일 수 있습니다

권한 모드 한눈에 보기

Bedrock 대화형 세션은 v2.1.283 이상에서 auto로 시작합니다

모드	묻지 않고 실행하는 것	맞는 경우
default (Manual)	읽기만	처음 보는 저장소, 운영 환경
acceptEdits	읽기, 파일 편집, mkdir·mv·cp 같은 파일 명령	익숙한 저장소의 반복 편집
plan	읽기 + (auto 가능 시) 분류기가 승인한 명령	설계 검토, 큰 변경 전
auto	전부, 백그라운드 안전 검사와 함께	경계 설정을 마친 뒤 일상 개발
dontAsk	작업 폴더 읽기와 사전 승인 도구만, 나머지는 거부	CI·헤드리스
bypassPermissions	전부, 검사 없음	격리된 컨테이너·VM만

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

auto mode의 판정 순서

권한 규칙이 첫 번째 문, 분류기가 두 번째 문

TWO GATES

deny·ask는 분류기보다 먼저 평가됩니다. Bash(*) 같은 넓은 allow는 auto 동안 정지됩니다.



© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

분류기가 기본으로 막는 것

설정하지 않아도 켜져 있는 규칙

EXEC

외부 코드 실행

curl | bash 같은 다운로드 후 실행

EXFIL

데이터 반출

민감 데이터 외부 전송
라이브 자격증명 출력

DESTROY

되돌릴 수 없는 일

force push, git reset --hard
terraform destroy, 클라우드 대량 삭제

PROD

운영

운영 배포·마이그레이션
prod 이름의 원격 대상

통과
작업 폴더 파일 작업

통과
lock 파일에 선언된 의존성 설치

통과
읽기 전용 HTTP

특수
rm 루트·홈·작업 폴더는 훅 allow로도 불가

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

승인을 추가하는 방법

확인 창이 반복되면 무엇을 고칠지 고르는 표

방법	어디에	효과
autoMode.environment	사용자 · managed	사내 Git·도메인·버킷을 "내부"로 알림. 가장 먼저 쓸 것
autoMode.allow	사용자 · managed	soft_deny의 예외를 문장으로 추가 (예: 스테이징 배포)
permissions.allow (좁게)	모든 스코프	Bash(npm test)처럼 분류기 전에 즉시 승인
대화에서 명시	해당 턴	정확한 행동을 지시하면 soft_deny를 넘김
/permissions → Recently blocked	세션	막힌 동작을 승인해 재시도
/permissions → Auto mode 탭	~/.claude/settings.json	파일 없이 항목 편집 (v2.1.246+)

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

금융사 예시 · autoMode 설정

항목은 정규식이 아니라 신입에게 설명하듯 쓰는 문장

~/.claude/settings.json 또는 managed-settings.json

```
{
  "permissions": {
    "ask":  ["Bash(git push *)", "Bash(gh pr create *)"],
    "deny": ["Read(./secrets/**)"]
  },
  "autoMode": {
    "environment": [
      "$defaults",
      "Organization: ACME Bank. Primary use: software development",
      "Source control: git.corp.example/acme and all repos under it",
      "Trusted internal domains: *.corp.example",
      "Sensitive data locations & audiences: s3://acme-customer-pii holds customer PII,
       never leaves the bank",
      "Sensitive remote targets: namespaces prod-*, hosts *.prod.corp.example"
    ],
    "soft_deny": ["$defaults", "Never run DB migrations outside the migration pipeline"],
    "hard_deny": ["$defaults", "Never send repository contents to third-party APIs"]
  }
}
```

꼭 지킬 것

- "$defaults"를 빼면 그 목록의 기본 규칙이 전부 사라짐
- autoMode는 프로젝트 .claude/settings.json에서 읽지 않음 (저장소 주입 방지)
- claude auto-mode config로 적용 결과 확인
- claude auto-mode critique로 규칙 리뷰

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

분류기 모델 고르기

판정은 별도 모델 호출입니다 (위에서부터 먼저 맞는 것)

조건	분류기 모델	비고
CLAUDE_CODE_AUTO_MODE_MODEL에 전체 모델 ID	지정한 모델	v2.1.302+, 추론 프로필 ID. Sonnet 5.5·Opus 5.5·Opus 5는 무시
Anthropic이 설정한 분류기 모델	그 모델	계정별
ANTHROPIC_DEFAULT_SONNET_MODEL 설정	그 값, 단 Sonnet 5.5·Opus 5.5면 Sonnet 5	이 랩: 기본 분류기 모델 (--debug-file·/status로 확인)
그 밖	Sonnet 5	기본값

폴백
지정 모델이 무시·제외되면 기본 분류기

실패
공급자가 못 주면 각 동작 거부

Bedrock
Sonnet 5 미활성이면 세션 모델로 폴백

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

분류기의 비용과 지연

Bedrock에서는 분류기 호출도 토큰 사용량입니다

드는 것

- 판정마다 대화 일부 + 실행할 동작을 전송
- 셸·네트워크 명령마다 왕복 지연
- classifyAllShell: true면 모든 셸 명령이 판정 대상
- 분류기 모델이 크면 비용도 큼

아끼는 것

- 읽기·작업 폴더 편집은 분류기 생략
- 사람이 기다리는 시간이 사라짐
- 승인 피로로 인한 실수 감소
- 작은 분류기 모델로 비용 조절

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

어디까지 허용할까 · 경계 설계

단단한 경계일수록 앞쪽 장치에 둡니다

경계	장치	금융권 예
절대 안 됨 (누구도 못 풂)	managed permissions.deny	고객 원장 경로 읽기, 운영 DB 접속 도구
사람이 반드시 확인	permissions.ask	git push, PR 생성, 배포 스크립트
분류기가 무조건 막음	autoMode.hard_deny	저장소 내용을 외부 API로 전송
막되 명시 의도로 풀림	autoMode.soft_deny	마이그레이션, 대량 삭제
신뢰 범위 안은 통과	autoMode.environment · allow	사내 Git, 사내 도메인, 스테이징
이번 세션만	대화로 선언	"검토 전까지 push 금지" — 압축되면 사라질 수 있음

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

조직이 거는 잠금

managed settings로 auto mode를 다루는 키

키	효과
permissions.disableAutoMode: "disable"	Shift+Tab 순환에서 auto 제거, --permission-mode auto도 Manual로 시작
autoMode (managed)	조직의 신뢰 범위·규칙 배포. 개발자는 항목 추가만, 삭제 불가
autoMode.classifyAllShell: true	좁은 Bash allow도 정지, 모든 셸 명령을 분류기로
useAutoModeDuringPlan: false	plan 모드에서는 분류기 대신 확인 창
permissions. disableBypassPermissionsMode	bypassPermissions 금지 (Ch2)

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

운영할 때 알아둘 것

auto mode가 스스로 멈추는 때와 남기는 기록

CIRCUIT

연속 차단 시 복귀

3회 연속·총 20회 차단 시 확인 창으로 복귀
(조정 불가)

SUBAGENT

Subagent

시작 전·실행 중·종료 후 검사
frontmatter permissionMode 무시

AUDIT

기록

PermissionDenied 훅으로 입력 수집
/permissions Recently blocked

BEDROCK

/auto-mode-setup

구독 플랜 + feature flag 필요
Bedrock은 environment를 직접 작성

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

QUICK CHECK · 손을 들어 답해 주세요

Q. auto mode에서 git push만은 항상 사람에게 묻게 하려면?

A

CLAUDE.md에 "push 전에 물어봐" 적기

B

permissions.ask에 Bash(git push *) 추가

C

autoMode.allow에 push 규칙 추가

정답 B · ask는 분류기보다 먼저 평가. git -C dir push 같은 변형은 PreToolUse 훅으로

CHAPTER 03 / PART 03

DLP 5층

나가는 길을 여러 단계로 좁힌다

1. 권한 규칙
2. 샌드박스
3. 훅
4. Bedrock Guardrails
5. 반출 채널

HONEST ANSWER

Claude Code에는 네이티브 DLP 기능이 없습니다

— 다섯 개의 층을 조합해 데이터가 나가는 길을 좁힙니다

DLP 5층

각 층은 앞 층이 놓친 것을 잡습니다

1	권한 규칙	민감 파일 읽기·위험 명령 차단. Bash 우회에 약함	`permissions.deny`
2	샌드박스	Bash의 파일·네트워크를 OS 수준에서 격리	`sandbox.network`
3	훅	프롬프트·도구 인자의 패턴 검사 예제, exit 2로 차단	`PreToolUse`
4	Bedrock Guardrails	모델로 가는 내용의 PII·민감정보 필터	`X-Amzn-Bedrock-*`
5	반출 채널	웹·MCP·플러그인·mod 경로 제한	`managed allowlist`

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

2층 샌드박스

권한 규칙이 못 막는 curl 빈틈을 OS가 막습니다

managed-settings.json (sandbox)

```
{
  "sandbox": {
    "enabled": true,
    "failIfUnavailable": true,
    "allowUnsandboxedCommands": false,
    "network": {
      "allowManagedDomainsOnly": true,
      "allowedDomains": [
        "api.github.example.com",
        "nexus.corp.example.com"
      ]
    }
  }
}
```

범위와 한계

- Claude가 실행하는 Bash 명령에 적용
- allowManagedDomainsOnly가 있으면 목록 밖 도메인은 연결 불가
- failIfUnavailable·비격리 재시도 금지로 우회 차단
- mod가 띄운 프로세스는 샌드박스 밖 (Ch5)

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

3층 DLP 훅 스크립트

프롬프트·도구 인자의 패턴 검사 예제 (5층 중 3층)

/opt/dlp/dlp-guard.sh

```
#!/bin/bash
INPUT=$(cat)
TEXT=$(echo "$INPUT" ¦ jq -r '.prompt // (.tool_input ¦ tostring)')

# 주민등록번호 · 카드번호 · AWS 액세스 키 (탐지 예시)
PAT='[0-9]{6}-[1-4][0-9]{6}¦[0-9]{4}-[0-9]{4}-[0-9]{4}-[0-9]{4}¦AKIA[0-9A-Z]{16}'

if echo "$TEXT" ¦ grep -Eq "$PAT"; then
  echo "DLP: 민감정보 패턴이 감지되어 차단했습니다" >&2
  exit 2   # 차단 (사유가 가는 곳은 오른쪽)
fi
exit 0
```

읽는 법

- UserPromptSubmit: .prompt 검사, 차단 사유는 사용자에게
- PreToolUse: .tool_input 검사, 사유(stderr)는 Claude에게
- exit 2만 차단
- 이 상태는 jq 실패 시 통과 → 다음 퀴즈
- 탐지 예시일 뿐, 운영 룰은 사내 DLP 기준

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

QUICK CHECK · 손을 들어 답해 주세요

Q. DLP 훅이 jq 미설치로 exit 127로 끝나면 어떻게 될까요?

A
차단된다

B
통과된다

C
세션이 종료된다

D
자동 재시도

정답 B · exit 2만 차단입니다. 그 외 0이 아닌 종료는 비차단 오류로 처리되어 그대로 진행됩니다

훅을 정책으로 강제

사용자가 끄지 못하게, 고장 나도 막히게

managed-settings.json + dlp-guard.sh 수정본

```
{
  "allowManagedHooksOnly": true,
  "hooks": {
    "UserPromptSubmit": [{ "hooks": [{ "type": "command",
      "command": "/opt/dlp/dlp-guard.sh", "onFailure": "block" }] }],
    "PreToolUse": [{ "matcher": "Bash¦Write¦Edit¦WebFetch",
      "hooks": [{ "type": "command",
        "command": "/opt/dlp/dlp-guard.sh", "onFailure": "block" }] }]
  }
}
#!/bin/bash
INPUT=$(cat)
TEXT=$(echo "$INPUT" ¦ jq -r '.prompt // (.tool_input ¦ tostring)') \
  ¦¦ { echo "DLP: 입력 해석 실패 - 차단" >&2; exit 2; }
PAT='[0-9]{6}-[1-4][0-9]{6}¦[0-9]{4}-[0-9]{4}-[0-9]{4}-[0-9]{4}¦AKIA[0-9A-Z]{16}'
echo "$TEXT" ¦ grep -Eq "$PAT"; RC=$?
[ "$RC" -eq 1 ] && exit 0   # 1 불일치 → 통과
echo "DLP: 차단 (grep $RC: 0 일치, 2+ 실행 오류)" >&2; exit 2
```

배포 포인트

- 스크립트도 관리자만 쓸 수 있는 경로에
- managed PreToolUse 차단은 최종 결정
- mod가 호출을 바꿔도 managed 훅이 다시 검사
- /hooks로 출처 확인
- onFailure: block → 스크립트 없음·시작 실패·타임아웃도 차단 (v2.1.295+)

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

4층 Bedrock Guardrails

모델로 가는 내용을 AWS가 걸러냅니다

managed-settings.json (env)

```
{
  "env": {
    "ANTHROPIC_CUSTOM_HEADERS":
      "X-Amzn-Bedrock-GuardrailIdentifier: gr-abc123\nX-Amzn-Bedrock-
       GuardrailVersion: 1"
  }
}
```

설정 포인트

- 콘솔에서 Guardrail 생성 후 버전 발행
- 민감정보 필터로 PII 마스킹·차단
- cross-region profile을 쓰면 Guardrail에도 Cross-Region inference 활성화
- 호출 역할에 bedrock:ApplyGuardrail 권한 필요
- 조직 강제: IAM 조건 bedrock:GuardrailIdentifier

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

5층 반출 채널

데이터가 나갈 수 있는 다른 통로를 닫습니다

WEB

웹

Bedrock은 내장 WebSearch 없음
WebFetch는 deny 또는 domain: 규칙으로 제한
검색 MCP도 허용 목록으로 관리
WebFetch 사전 검사가 호스트명을 Anthropic으로 보냄 → skipWebFetchPreflight

MCP

외부 도구

managed MCP 허용 목록
allowedMcpServers
allowManagedMcpServersOnly

EXTENSIONS

플러그인·mod

마켓플레이스 허용 목록
사이드로드 금지
사용자 mod 차단

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

CHAPTER 03 / PART 04

확장 통제와 감사

무엇이 설치되고, 무엇이 남는가

확장 통제 키

플러그인·MCP·mod를 managed settings로

키	효과	함께 쓸 것
strictKnownMarketplaces	허용한 마켓플레이스만	extraKnownMarketplaces
blockedMarketplaces	특정 소스 차단 (허용 목록보다 먼저)	—
enabledPlugins: false	특정 플러그인 차단·숨김	—
disableSideloadFlags	--plugin-dir, --mcp-config 등 거부	허용 목록
strictPluginOnlyCustomization	플러그인 밖 스킬·Subagent·훅·MCP 차단	사내 마켓플레이스
pluginConfigs → allowManagedModsOnly	사용자가 설치한 mod 차단	Ch5

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

무엇이 기록으로 남는가

감사 질문에 답할 수 있는 근거

남는 것

- PC: 세션 JSONL (cleanupPeriodDays)
- AWS: CloudTrail의 Bedrock 호출 이력
- AWS: Bedrock model invocation logging (선택, 프롬프트 원문 포함)
- OTel(OpenTelemetry): 사용자별 토큰·비용·도구 (Ch6)

주의할 것

- invocation logging은 원문이 저장되므로 저장소·보존 정책 필요
- Anthropic으로 가는 텔레메트리는 Bedrock에서 기본 꺼짐
- 단, WebFetch 사전 검사는 호스트명을 api.anthropic.com으로 보냄 (skipWebFetchPreflight로 끔)
- ZDR(Zero Data Retention)은 AWS 계약 조건에 따름
- 세션 로그도 고객 데이터를 담을 수 있음

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

감사에서 자주 받는 질문

어떤 기록으로 답할 수 있는지 한 장으로 정리합니다

질문	근거가 되는 기록	챕터
누가 언제 썼나	CloudTrail의 Bedrock 호출 · 게이트웨이 사용자(OIDC)	Ch2 · Ch6
어떤 모델을 썼나	managed settings의 모델 고정 · inference profile	Ch2
무엇을 실행했나	OTel 이벤트 (tool_decision · tool_result) · 세션 JSONL	Ch3 · Ch6
무엇을 막았나	DLP 훅 차단 메시지 · auto mode 거부 기록 (/permissions)	Ch3
정책은 언제 바뀌었나	managed settings 배포 이력 (MDM · git)	Ch2
고객 데이터가 나갔나	권한 규칙 · 샌드박스 · DLP 훅 · Guardrails의 차단 기록	Ch3

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

LAB · TASK 00~02 · 15분

DLP 훅 만들고 fail-open 확인하기

1. TASK 01 · dlp-guard.sh 작성, 실행 권한 부여
2. TASK 01 · managed settings에 UserPromptSubmit·PreToolUse 등록
3. TASK 01 · 가짜 주민번호(900101-1234567)로 차단 확인
4. TASK 02 · jq를 깨뜨려 고장 난 훅이 통과되는지 확인
5. TASK 02 · 오류 경로에 exit 2를 넣어 fail-closed로 수정
6. TASK 07 · 전체 원복 (필수, Ch5·Capstone 전에)

테스트 데이터만 사용 · Hands-on Lab 포털 → Chapter 3 TASK 00(사전 준비 2분)부터

LAB · TASK 03 · 15분

auto mode로 승인 줄이고 경계 긋기

1. --debug-file로 분류기 모델 확인하고 auto로 시작
2. 안전한 작업은 묻지 않고 진행하는 것, curl | bash는 내용부터 확인하는 것 보기
3. permissions.ask로 git push 사람 확인 넣기
4. autoMode.environment·hard_deny에 고객 데이터 위치를 적고 critique로 검토
5. managed disableAutoMode로 조직 잠금 → 원복

Hands-on Lab 포털 → Chapter 3 TASK 03 · 끝나면 TASK 07 원복(2분)

CHAPTER 03 / DEEP DIVE

더 알아보기

자주 받는 질문과 세부 설정

1. 권한 규칙 문법
2. 훅이 끼어드는 지점
3. 훅의 JSON 결정
4. OS별 훅·샌드박스 차이
5. MCP 서버 통제
6. 감사 기록은 어디에

권한 규칙 문법

도구(지정자) 형태로 범위를 좁힌다

규칙	의미	주의
Bash(npm run test *)	접두사가 같은 명령	셸 우회(파이프·서브셸)에 약함
Read(./secrets/**)	gitignore 스타일 경로	상대 경로 기준 확인
Edit(~/.ssh/**)	홈 경로 편집	deny는 모든 스코프보다 우선
WebFetch(domain:corp.example)	도메인 단위	허용 목록으로 쓰는 것이 안전
mcp__github__create_issue	MCP 도구 단위	서버 전체는 mcp__github

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

훅이 끼어드는 지점

루프의 어느 지점에 끼어드는가

이벤트	시점	DLP 용도
UserPromptSubmit	프롬프트 전송 전	입력의 민감정보 차단
PreToolUse	도구 실행 전	명령·파일 쓰기·웹 요청 차단
PostToolUse	도구 실행 후	결과 검사, 기록
SessionStart	세션 시작	사내 규정 컨텍스트 주입
Stop · SubagentStop	응답 종료	산출물 점검, 알림
PreCompact	압축 전	요약 전 기록 보존

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

훅의 JSON 결정

exit 2보다 세밀하게 말하기

hook stdout

```
{
  "hookSpecificOutput": {
    "hookEventName": "PreToolUse",
    "permissionDecision": "deny",
    "permissionDecisionReason": "고객 원장 경로는 읽을 수 없습니다"
  }
}
```

선택지

- deny: 차단하고 이유를 Claude에게 전달
- ask: 사용자에게 확인 요청
- allow: 확인 없이 진행
- updatedInput: 명령 자체를 바꿈 (Ch6 필터)
- 단순 차단은 exit 2 + stderr

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

DLP 훅과 샌드박스의 OS 차이

같은 정책이라도 OS마다 준비물이 다릅니다

항목	macOS	Linux · WSL2 (랩)	Windows
훅 스크립트	bash · zsh	bash	Git Bash 또는 powershell -File
jq 같은 의존성	brew로 배포	dnf · apt로 배포	별도 배포 필요
의존성 누락 시	fail-open 위험	fail-open 위험	fail-open 위험이 가장 큼
샌드박스	Seatbelt 내장	bubblewrap + socat 설치	WSL2 안에서만
스크립트 배치	/Library/… 아래 root 소유	/opt · /etc 아래 root 소유	Program Files 아래 관리자 소유

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

MCP 서버 통제

새 반출 채널을 정책으로 닫는다

managed-settings.json

```
{
  "allowManagedMcpServersOnly": true,
  "allowedMcpServers": [
    { "serverUrl": "https://mcp.corp.example.com/*" },
    { "serverCommand": ["python", "/opt/mcp/jira.py"] }
  ],
  "deniedMcpServers": [
    { "serverName": "filesystem" }
  ]
}
```

포인트

- MCP 서버 하나 = 외부로 나가는 통로 하나
- allowManagedMcpServersOnly로 managed 목록만 인정
- 목적지는 serverUrl·serverCommand로 고정
- 거부 목록이 허용보다 우선
- 플러그인에 든 MCP도 같은 정책을 받음

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

감사 기록은 어디에

사고가 나면 무엇을 볼 수 있는가

기록	내용	관리 포인트
세션 JSONL	대화와 도구 결과 전체 (로컬)	보존 기간, PC 반출 통제
OTel 이벤트	tool_decision · tool_result · api_request	프롬프트 본문 삭제 후 수집
CloudTrail	누가 언제 Bedrock을 호출했나	조직 트레일로 중앙화
Bedrock 호출 로깅	프롬프트·응답 본문 (S3·CloudWatch)	켜면 그 자체가 민감 데이터
게이트웨이	사용자별 지출·감사	OIDC sub 기준, 개인정보 보존 기간

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

DESIGN RULE

DLP는 탐지율보다 남은 우회 경로의 수로 평가합니다

— 막은 것보다 열려 있는 길을 목록으로 관리하세요

Chapter 3 Recap

가드레일 한 장 요약

01 권한은 합쳐서 deny 먼저, 잠금 키는 managed로 배포

02 네이티브 DLP는 없다, 5층을 조합한다

03 샌드박스는 Bash의 curl 빈틈을 막는다

04 훅은 exit 2만 차단, 오류 경로도 exit 2로

05 Guardrails는 Bedrock 사용 시 AWS 계정 쪽에서 거는 층

06 확장은 허용 목록 + 사이드로드 금지 + mod 차단

07 auto mode: deny·ask가 먼저, 신뢰 범위는 environment, 분류기 모델은 확인

© 2026, Amazon Web Services, Inc. or its affiliates. All rights reserved. Amazon Confidential and Trademark.

Thank you!

다음: Chapter 4 · Subagents와 병렬 에이전트

Slack #20261116-claude-code-workshop-for-fsi · 질문은 언제든 편하게 남겨 주세요